

Module title: Information Security, Management and Compliance

Month and Year: November 2025

1. Overview:

Heathrow Airport Holdings Limited is world's best connecting airport operator and UK's only hub airport company. London Heathrow Airport (LHR) is recognised as part of nation's Critical National Infrastructure (CNI), as it plays a very important role in supporting UK economy whether passengers going on holidays to small business trading, Heathrow is a national asset (Heathrow Airport Holdings Limited, 2024). Heathrow's objective is to remain the world's most connected hub which will enable the UK's long-term prosperity through safe, sustainable, and efficient operations. The ecosystem relies heavily on vast digital connectivity for passenger management, air traffic coordination, baggage logistics, and supplier interfaces, stressing Heathrow's need for robust information security governance (Heathrow, 2024).

Heathrow Airport's operations are performed keeping three main priorities in focus which are 1) keeping passengers and operations safe and secure, 2) providing good service, and 3) managing finances responsibly (Heathrow Airport Holdings Limited, 2024). Hence, Information security is a crucial part of achieving these goals as modern airport operations totally depend on secure and reliable computer systems.

1.1 External Context:

Heathrow follows strict UK and European laws and regulations. These include the UK Data Protection Act 2018, General Data Protection Regulation (GDPR), Civil Aviation Authority (CAA) rules, and UK government cybersecurity requirements for critical infrastructure. Because Heathrow is classified as CNI, it aligns with ISO/IEC 27001:2022 and ISO/IEC 27005:2022, showing commitment to international best practice standards (Heathrow Airport Holdings Limited, 2024).

1.2 **Internal Context:

Heathrow's daily operations depends on multiple interconnected computer systems and software applications. Some of which are managed by Heathrow's own IT team while others are managed by third party suppliers. All the applications, software and systems deployed with their roles in LHR premises are listed in **Appendix 1**.

1.3 Assumptions: Headings beginning with double asterisk (**) means it has been assumed for Heathrow Airport.

1.4 Scope and Boundaries:

1.4.1 This information security project covers all computer systems, data and supplier services (assets listed in the appendix 1) that support Heathrow Airport's functioning in the UK. The ISMS shall be operated in accordance with the Statement of Applicability version 3.03 dated 13/10/2025 (University of Hertfordshire, 2025).

1.4.2 The ISMS shall protect the confidentiality, integrity and availability of Heathrow Airport Holdings Limited customer data at all times while in UK offices. This includes IT departments, call centres and HAHN office locations. The ISMS shall be operated in accordance with the Statement of Applicability version 3.03 dated 13/10/2025 (University of Hertfordshire, 2025).

1.4.3 **Geographic Area:

The project only focus on systems and operations at London Heathrow Airport Facility. Any offices outside the UK are out of scope unless they directly affect LHR airport operations.

1.4.4 Why this scope makes sense:

By focusing on these systems and suppliers, we concentrate on protecting what matters most which is safe airport operations, passenger data protection, and legal compliance. This approach ensures risk management efforts target the highest-

priority areas which is in line with Heathrow's strategic objectives (Heathrow Airport Holdings Limited, 2024).

1.5 Needs and Expectations of Interested Parties:

Below are the stakeholders who depend on Heathrow's information security:

- 1.5.1 Passengers:** Every single person travelling expects their personal information like name, payment details and travel documents to be kept safe and private. They want all their personal data to be protected as required by GDPR and the UK Data Protection Act 2018 (GDPR, 2018) (UK Government, 2025).
- 1.5.2 Airlines:** Airlines require reliable check-in systems, accurate baggage tracking, secure communications for coordinating flights, and consistent & uninterrupted airport operations (LHR Airports Limited, 2025).
- 1.5.3 UK Government and Regulators:** UK Government requires Heathrow Airport to follow all cybersecurity rules for critical infrastructure and aviation regulations which is set by the Civil Aviation Authority (CAA), and data protection laws. Not complying to this can lead to the regulators or government imposing heavy penalties and affecting the reputation of Heathrow Airport.
- 1.5.4 Suppliers:** All suppliers must follow the contract agreement and security requirements with Heathrow Airport. Suppliers are expected to implement security controls similar to BS ISO/IEC 27001 standards and report any security problems to LHR immediately (BS EN ISO/IEC 27001, 2024).
- 1.5.5 Public and Communities:** The general public and communities expect that LHR be absolute transparent about its security measures and be accountable if any security incident happens.
- 1.5.6 Employees and Contractors:** The employees and contractors need their systems to be efficient and secure so that they can do their jobs properly and expect their personal information to be safe and secure.

1.6 Supplier Governance Framework:

Heathrow Airport Limited Condition of Use document states clear requirements for suppliers for use of airport facilities and services. The conditions state:

- 1.7 Data Protection Compliance:** The suppliers have to follow and comply with all relevant data protection legislations like GDPR and the UK Data Protection Act 2018. The conditions laid out state that suppliers should perform their respective roles without causing breach of any of these laws to either of the party. Which means LHR requires strict handling, processing and protection of passenger or operational data (Heathrow Airport Limited, 2024).
- 1.8 Notification of IT/System Changes:** Suppliers must inform LHR promptly and in advance of any IT system or infrastructure changes that might impact Heathrow Airport's operational systems or airport performance. This ensures that LHR can assess the risk and coordinate changes to avoid any disruptions in the Airport operation (Heathrow Airport Limited, 2024).
- 1.9 Mandate use of Standard Systems:** Wherever Heathrow Airport operates the Common Use Passenger Processing System (CUPPS), the suppliers and airlines have to use it for their operations unless explicitly granted any alternate arrangements on Heathrow Airport's sole discretion also depending if it can be properly integrated with Heathrow Airport IT systems (Heathrow Airport Limited, 2024).
- 1.10 Information Security Basic Criteria:** Please see **Appendix 1** which outlines how Heathrow Airport decides the basic criteria and if a risk is acceptable.
- 1.11 Threat Landscape:** Please refer to **Appendix 1**.
- 1.12 Organisational Responsibilities and Governance:** As per ISO standard 27001 clause 5.3 and ISO 27005 clause 6.1, please refer to **Appendix 1** for the roles and responsibilities:

2. **Risk Assessment:** Please refer the Appendix 2 Risk Assessment Excel sheet.
3. **Policy for Information security within supplier agreements:**

INFORMATION SECURITY IN SUPPLIER AGREEMENTS POLICY

Heathrow Airport Holdings Limited (LHR) – United Kingdom

Version 2.0 | Status: Approved | Classification: Confidential

Date of policy:	15-November-2025
Author:	Ashley Shin
Version:	2
Approval Date:	21-November-2025
Next Review Date:	21-November-2026

1. Policy Development and Governance

This policy has been developed through collaboration between Information Security and the CISO Office, IT and Operational Technology (OT) Management, Legal and Procurement, the Data Protection Officer (DPO), Senior Administration, staff representatives, and a technical policy writer/editor. This multidisciplinary review ensures alignment with operational needs, regulatory obligations, contractual expectations, and organisational governance.

2. Organisational Context and Security Approach

Heathrow Airport Holdings Limited (LHR) operates as a part of the United Kingdom's Critical National Infrastructure. The resilience and security of the airport's information systems, operational environments, and personal data processing are essential to the protection of life, business continuity, aviation safety, corporate reputation, and compliance with statutory and regulatory requirements. The airport enforces a strict security posture in which access is denied by default and only granted when explicitly authorised and justified.

3. Risk and Threat Considerations

Suppliers introduce a number of potential risks to airport operations and data security. These include the risk of unauthorised access or misuse of privileged functionality, operational disruption caused by exploitation of technical vulnerabilities, loss of service availability, breaches of personal data, compromise of surveillance and physical security systems, and interception or manipulation of communications. This policy mandates controls to ensure that such risks are effectively identified, mitigated, and managed throughout the supplier relationship lifecycle.

4. Purpose

The purpose of this policy is to ensure that information security and data protection requirements are embedded within all supplier engagements and contract agreements. It seeks to protect the confidentiality, integrity, and availability of Heathrow Airport Holdings Limited (LHR) information assets and systems while ensuring full compliance with standards such as ISO/IEC 27001 and legal frameworks including UK GDPR.

5. Scope

This policy applies to all suppliers, contractors, managed service providers, cloud service providers, and subcontracted entities engaged by Heathrow Airport Holdings Limited (LHR) who access or process airport information, support or maintain IT or OT assets, or connect any component to the airport network. Compliance requirements apply from the point of procurement and onboarding through operational delivery and eventual offboarding, including data return or secure destruction.

6. Information Security Policy Requirements

6.1 Privileged Access Policy

Privileged access must be restricted to the minimum necessary, reviewed quarterly, and immediately revoked when no longer required to prevent misuse of elevated permissions.

6.2 System Update and Patch Policy

All systems that suppliers manage for the airport must be maintained in a fully updated and patched state to reduce the risk of service disruption and security compromise.

6.3 Input Validation Policy

All application inputs must be validated and sanitised prior to processing, storage, or display to protect systems from injection and cross-site scripting attacks.

6.4 Secure Configuration Policy

Systems must be securely configured, disabling weak or vulnerable components and applying security controls to prevent privilege escalation and unauthorised system modification.

6.5 Restricted Update Infrastructure Policy

Update and management infrastructure must only be accessible to authorised systems and required update services, and all other inbound connectivity must be actively blocked.

6.6 Public Interface Hardening Policy

Public-facing application interfaces and unnecessary externally accessible functions must be disabled or restricted, ensuring only approved endpoints remain available.

6.7 Role-Based Data Access Policy

Access to data must be strictly role-based, ensuring that users, systems, and integrations access only the information required for operational responsibilities.

6.8 Transaction Integrity Policy

Sensitive transactions and API operations must use secure cryptographic controls such as nonces to prevent replay, manipulation, or unauthorised execution.

6.9 Physical Security System Segmentation Policy

Surveillance and physical security systems must be segmented from public networks, regularly updated, and protected using secure firewall controls to prevent unauthorised access.

6.10 Asset Remediation Policy

All vulnerable or affected devices must be identified, assessed, and remediated with appropriate technical, physical, or administrative controls within acceptable timeframes.

6.11 Administrative Access Isolation Policy

Administrative interfaces must only be accessible from authorised management networks and isolated within dedicated and secure network segments.

6.12 Network Access Control Policy

Firewall rules and access control lists must be applied to limit connectivity to only required services, reducing attack surface and exposure to unauthorised access.

6.13 Web Traffic Header Protection Policy

Web communications must enforce protections that prevent unauthorised modification of request or response headers and ensure only trusted and validated metadata is processed.

6.14 Secure Proxy Administration Policy

Administrative access to security gateways, proxies, and similar systems must be restricted to approved IP addresses and authorised personnel only.

6.15 Authentication Security Policy

All authentication services must enforce strong multi-factor authentication and monitor for suspicious activity, blocking sign-in attempts from untrusted or anomalous sources.

6.16 Secure Monitoring Communication Policy

Monitoring and security telemetry systems must encrypt communication channels and implement protections that prevent interception and unauthorised disclosure of security data.

6.17 Operating System Security Policy

Operating systems must be patched promptly and configured to disable or manage features that could enable privilege escalation or execution of malicious processes.

7. Data Protection Requirements

Suppliers processing personal data on behalf of Heathrow Airport Holdings Limited (LHR) must do so only under the explicit instruction of the airport in accordance with lawful processing requirements. A Data Processing Agreement will govern responsibilities, ensuring appropriate technical and organisational measures, restricted access to personal data, accountability for audit logging, and support for data subject rights. Any incident involving personal data must be reported without undue delay to enable regulatory notification as required. The airport remains the Data Controller at all times.

8. Acceptable Use and Prohibited Practices

Suppliers are required to operate within the airport's approved security framework and must not bypass established security controls, introduce unauthorised technology or connectivity, export data beyond approved environments, or make operational changes without prior authorisation. Sharing or reusing privileged credentials or authentication materials is strictly prohibited, and any such behaviour may trigger contractual or legal response.

9. Audit, Monitoring and Compliance Enforcement

Suppliers must provide evidence of compliance upon request and allow the airport or authorised third parties to conduct audits, assessments, and penetration testing where necessary. Suppliers are expected to provide logs, patch records, and remediation documentation and cooperate fully with incident investigations. Contractual enforcement actions will be applied proportionately where non-compliance is identified.

10. Incident Reporting Requirements

Suppliers are required to immediately report any suspected or confirmed security incidents to the designated airport security contact, maintain the integrity of digital evidence, and refrain from changes that could hinder forensic investigation or remediation. Escalation contacts must be made available to the airport.

11. Subcontractor Controls

Any subcontracting arrangement must be formally approved in writing by the airport before engagement. Subcontractors must adhere to the same security requirements as the primary supplier, and primary suppliers remain fully accountable for the performance and compliance of their subcontractors.

12. Enforcement and Policy Violations

If a supplier breaches this policy, the airport may enforce appropriate sanctions including suspension of access, service discontinuation, contract termination, financial recovery of loss or damages, and escalation to regulatory bodies. Enforcement decisions will be guided by the severity and risk impact of the violation.

13. Exceptions

Any deviation from this policy must be formally documented, fully risk assessed, and approved by both the CISO and the Data Protection Officer. Unauthorised exceptions are not permitted under any circumstances.

14. Review and Maintenance

This policy will be reviewed at least annually or following significant changes in regulatory obligations, supplier arrangements, or cyber risk conditions. Any updates made must follow appropriate ISMS change governance.

Management sign off

Executive Director accountable for this policy:

Name: Dr. Deepthi Ratnayake

Date:

Function policy lead

Name: Dr. Anish Saini

Date:

REFERENCE LIST:

1. Heathrow Airport Holdings Limited (2024) *HEATHROW AIRPORT HOLDINGS LIMITED COMPANY REGISTRATION NUMBER: 05757208*. Available at: https://www.heathrow.com/content/dam/heathrow/web/common/documents/company/investor/reports-and-presentations/annual-accounts/airport-holdings/HAHL_ARA_2024.pdf. (Accessed: 3 November, 2025)
2. Heathrow (2024) *Our strategy* | *Heathrow, Heathrow Airport*. Available at: <https://www.heathrow.com/company/about-heathrow/our-strategy>. (Accessed: 4 November, 2025)
3. Collins Aerospace (2025) *Agent-Assisted Check-In*, *@CollinsAero*. Available at: <https://www.collinsaerospace.com/what-we-do/industries/airports/passenger-processing-solutions/agent-assisted-check-in>. (Accessed: 4 November)
4. Flyware (2024) *Products - Flyware, Flyware.net*. Available at: <https://flyware.net/products/> (Accessed: 4 November 2025).
5. Vanderlande (2015) *control software suite VANDERLANDE*, <http://twitter.com/DirectIndustry>. Available at: <https://www.directindustry.com/prod/vanderlande/product-5796-2503567.html> (Accessed: 4 November 2025).
6. Red Hat (2024) *Red Hat Enterprise Linux, Redhat.com*. Available at: <https://access.redhat.com/products/red-hat-enterprise-linux>. (Accessed: 4 November, 2025)
7. Dell Technologies (2022) *Microsoft Windows Server 2022* | *Dell UK, Dell*. Available at: <https://www.dell.com/en-uk/lp/dt/workloads-microsoft-windows-server> (Accessed: 4 November 2025).
8. Palo Alto (2025) *PAN-OS, docs.paloaltonetworks.com*. Available at: <https://docs.paloaltonetworks.com/pan-os>. (Accessed: 4 November, 2025)
9. Cloudflare (2025) *Cloudflare WAF, Cloudflare.com*. Available at: <https://www.cloudflare.com/lp/waf-product-brief-xy/>. (Accessed: 4 November, 2025)
10. Fortinet (2025) *Fortinet FortiProxy, Fortinet*. Available at: <https://www.fortinet.com/uk/products/secure-web-gateway/fortiproxy> (Accessed: 4 November 2025).
11. Okta (2025) *Multi-Factor Authentication (MFA) Solutions* | *Okta, Okta.com*. Available at: <https://www.okta.com/en-gb/products/adaptive-multi-factor-authentication/> (Accessed: 5 November 2025).
12. Microsoft (2025) *Windows 11 Enterprise* | *Microsoft 365, www.microsoft.com*. Available at: <https://www.microsoft.com/en-us/microsoft-365/windows/windows-11-enterprise>. (Accessed: 5 November, 2025)

13. Lisa Dodson (2024) *The Rise of Oracle Fusion Cloud ERP: A Game-Changer in ERP Solutions*, *ERP Today*. Available at: <https://erp.today/the-rise-of-oracle-fusion-cloud-erp-a-game-changer-in-erp-solutions/> (Accessed: 13 November 2025).
14. Oracle (2024) *Heathrow meets business boom with deeper ERP and HCM analytics*, *Oracle.com*. Available at: <https://www.oracle.com/uk/customers/heathrow/> (Accessed: 13 November 2025).
15. Drake, J. (2022) *Heathrow Airport Takes Off with Oracle Cloud*, *Oracle.com*. Available at: <https://www.oracle.com/uk/news/announcement/heathrow-airport-takes-off-with-oracle-cloud-2022-01-24/>. (Accessed: 13 November 2025)
16. Stripe (2025) *Security at Stripe*, *docs.stripe.com*. Available at: <https://docs.stripe.com/security>. (Accessed: 13 November 2025)
17. Cisco (2025) *Cisco Catalyst 9300 Series Switches*, *Cisco*. Available at: <https://www.cisco.com/site/us/en/products/networking/switches/catalyst-9300-series-switches/index.html>. (Accessed: 13 November 2025)
18. Microsoft (2018) *Heathrow prepares rather than reacts: uses data to deliver airport calm* | *Microsoft Customer Stories*, *Microsoft.com*. Available at: <https://www.microsoft.com/en/customers/story/709586-heathrow-airport-travel-transportation-powerbi-azure>. (Accessed: 13 November 2025)
19. CrowdStrike (2024) *What is Next-Generation Antivirus (NGAV)?* | *CrowdStrike*, *Crowdstrike.com*. Available at: <https://www.crowdstrike.com/en-us/cybersecurity-101/endpoint-security/next-generation-antivirus-ngav/>. (Accessed: 14 November 2025)
20. Bailey, D. (2025) *Heathrow Terminal 5 gets wired with Cisco, and unwired with Aruba*, *Computing.co.uk*. Available at: <https://www.computing.co.uk/news/1828617/heathrow-terminal-wired-cisco-unwired-aruba> (Accessed: 14 November 2025).
21. HPE Aruba (2025) *Example Use Case*, *Hpe.com*. Available at: <https://arubanetworking.hpe.com/techdocs/central/2.5.7/content/nms/apps/acn/example-use-cases.htm> (Accessed: 14 November 2025).
22. BSI (2022) *BS EN ISO/IEC 27002:2022*, *login.ezproxy.herts.ac.uk*. Available at: <https://bsol-bsigroup-com.ezproxy.herts.ac.uk/PdfViewer/Viewer?pid=000000000030390395> (Accessed: 14 November 2025).
23. University of Hertfordshire (2025) *Scope and Boundaries* [Lecture Slides]. Information Security Management Compliance (7COM1066-0901-2025). University of Hertfordshire. Available at: University of Hertfordshire Canvas (Accessed: 14 November 2025).
24. GDPR (2018) *General Data Protection Regulation (GDPR)*, *GDPR*. Available at: <https://gdpr-info.eu/> (Accessed: 15 November 2025)
25. UK Government (2025) *Data Protection Act*, *Gov.uk*. [www.gov.uk](https://www.gov.uk/data-protection). Available at: <https://www.gov.uk/data-protection> (Accessed: 15 November 2025)

26. LHR Airports Limited (2025) *Economic Regulation | Heathrow, Heathrow Airport*. Available at: <https://www.heathrow.com/company/about-heathrow/economic-regulation> (Accessed: 15 November 2025)
27. BS EN ISO/IEC 27001 (2024) *BS EN ISO/IEC 27001:2023+A1:2024*, *Herts.ac.uk*. Available at: <https://bsol-bsigroup-com.ezproxy.herts.ac.uk/PdfViewer/Viewer?pid=000000000030486838>. (Accessed: 15 November 2025)
28. Heathrow Airport Limited (2024) *Heathrow Airport Limited Conditions of Use including Airport Charges from 1 January 2025*. Available at: <https://www.heathrow.com/content/dam/heathrow/web/common/documents/company/doing-business-with-heathrow/flights-condition-of-use/conditions-of-use-documents/2025/Heathrow-Airport-Limited-Conditions-of-Use-2025.pdf> (Accessed: 15 November 2025).
29. University of Hertfordshire (2025) *Basic Criteria* [Lecture Slides]. Information Security Management Compliance (7COM1066-0901-2025). University of Hertfordshire. Available at: University of Hertfordshire Canvas (Accessed: 14 November 2025).
30. SafetyCulture 2022. *5x5 Risk Matrix: Importance and Examples*. [online] SafetyCulture. Available at: <https://safetyculture.com/topics/risk-assessment/5x5-risk-matrix/> (Accessed: 15 November 2025).
31. BSI (2017) *BS ISO/IEC 27003:2017*, *Herts.ac.uk*. Available at: <https://bsol-bsigroup-com.ezproxy.herts.ac.uk/PdfViewer/Viewer?pid=000000000030286014> (Accessed: 15 November 2025).
32. Davies, M., Heyndyk, R. M. and Tidy, J. (2025) 'Heathrow cyber-attack: Day of delays after airport check-in system hit', *BBC News*, 20 September. Available at: <https://www.bbc.co.uk/news/articles/c3drpgv33pxo> (Accessed: 16 November 2025).
33. Pure Cyber (2025) *Grounded by Hackers: Why UK Airports & Airlines Are Prime Targets for Cyber Attacks*, *PureCyber*. Available at: <https://purecyber.com/news-1/why-uk-airports-and-airlines-are-prime-targets-for-cyber-attacks> (Accessed: 16 November 2025).
34. Cohen, O. (2025) *5 Ways OAuth Can Go Wrong (and How to Avoid Them)*, *Descope*. Available at: <https://www.descope.com/blog/post/5-oauth-misconfigurations> (Accessed: 17 November 2025).
35. LianKee (2025) *SO-CVEs/CVEs/CVE-2023-29759/CVE detailed.md at main · LianKee/SO-CVEs*, *GitHub*. Available at: <https://github.com/LianKee/SO-CVEs/blob/main/CVEs/CVE-2023-29759/CVE%20detailed.md> (Accessed: 18 November 2025).
36. BSI (2024) *BS EN ISO/IEC 27005:2024*, *Herts.ac.uk*. Available at: <https://bsol-bsigroup-com.ezproxy.herts.ac.uk/PdfViewer/Viewer?pid=000000000030490478> (Accessed: 18 November 2025).

37. Souppaya, M. and Scarfone, K. (2022) *Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology*, *csrc.nist.gov*. Available at: <https://csrc.nist.gov/pubs/sp/800/40/r4/final> (Accessed: 18 November 2025).
38. MITRE (2006) *CWE - CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') (4.1)*, *cwe.mitre.org*. Available at: <https://cwe.mitre.org/data/definitions/79.html> (Accessed: 18 November 2025).
39. OWASP (2021) *Cross Site Scripting Prevention - OWASP Cheat Sheet Series*, *OWASP.org*. Available at: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html (Accessed: 18 November 2025).
40. Red Hat (2025) *cve-details*, *Redhat.com*. Available at: <https://access.redhat.com/security/cve/CVE-2024-1086> (Accessed: 19 November 2025).
41. Unit 42 (2025) *Microsoft WSUS Remote Code Execution (CVE-2025-59287) Actively Exploited in the Wild (Updated October 28)*, Unit 42. Available at: <https://unit42.paloaltonetworks.com/microsoft-cve-2025-59287/> (Accessed: 19 November 2025).
42. Picus (2025) *Oracle EBS CVE-2025-61882 Vulnerability: Pre-auth SSRF Leads to Remote Code Execution*, *Picussecurity.com*. Available at: <https://www.picussecurity.com/resource/blog/oracle-ebs-cve-2025-61882-vulnerability> (Accessed: 19 November 2025).
43. Hudson, C. et al. (2025) *Exploitation of Windows Server Update Services Remote Code Execution Vulnerability (CVE-2025-59287)*, *Huntress*. Available at: <https://www.huntress.com/blog/exploitation-of-windows-server-update-services-remote-code-execution-vulnerability> (Accessed: 19 November 2025).
44. CVE (2022) *CVE-2022-21636*, *Cve.org*. Available at: <https://www.cve.org/CVERecord?id=CVE-2022-21636> (Accessed: 19 November 2025).
45. Oracle (2022) *Oracle Critical Patch Update Advisory - October 2022*, *Oracle.com*. Available at: <https://www.oracle.com/security-alerts/cpuoct2022.html> (Accessed: 19 November 2025).
46. CVE (2019) *MITRE CVE-2018-19249*, *Cve.org*. Available at: <https://www.cve.org/CVERecord?id=CVE-2018-19249> (Accessed: 19 November 2025).
47. Packetlabs (2024) *A Guide to Replay Attacks And How to Defend Against Them*, *Packetlabs*. Available at: <https://www.packetlabs.net/posts/a-guide-to-replay-attacks-and-how-to-defend-against-them/> (Accessed: 20 November 2025).
48. CrowdStrike (2025) *CVE 2025-1146 - CrowdStrike Falcon Sensor for Linux TLS Issue*, *Crowdstrike.com*. Available at: <https://www.crowdstrike.com/en-us/security-advisories/cve-2025-1146/> (Accessed: 20 November 2025).

49. SentinelOne (2025) *CVE-2025-1146: CrowdStrike Falcon TLS Validation Flaw*, *SentinelOne*. Available at: <https://www.sentinelone.com/vulnerability-database/cve-2025-1146/> (Accessed: 20 November 2025).
50. SentinelOne (2025b) *CVE-2025-21335: Windows Hyper-V Privilege Escalation Flaw*, *SentinelOne*. Available at: <https://www.sentinelone.com/vulnerability-database/cve-2025-21335/> (Accessed: 20 November 2025).
51. NIST (2023) *NVD - CVE-2023-20082*, *Nist.gov*. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2023-20082> (Accessed: 20 November 2025).
52. Cisco (2020) *System Management Configuration Guide, Cisco IOS XE Amsterdam 17.3.x (Catalyst 9300 Switches) - Boot Integrity Visibility [Support]*, *Cisco*. Available at: https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst9300/software/release/17-3/configuration_guide/sys_mgmt/b_173_sys_mgmt_9300_cg/boot_integrity_visibility.html (Accessed: 20 November 2025).
53. NIST (2025) *NVD - CVE-2021-36260*, *Nist.gov*. Available at: <https://nvd.nist.gov/vuln/detail/CVE-2021-36260> (Accessed: 20 November 2025).
54. Heiland, D. (2020) *UPnP, SSDP, and Port Forwarding Services Explained* | *Rapid7 | Rapid7 Blog*, *Rapid7*. Available at: <https://www.rapid7.com/blog/post/2020/12/22/upnp-with-a-holiday-cheer/> (Accessed: 20 November 2025).
55. Netwrix (2025) *Guide to Network Security Best Practices* | *Netwrix*, *Netwrix.com*. Available at: <https://netwrix.com/en/resources/guides/network-security-best-practices/> (Accessed: 20 November 2025).
56. Mattias Geniar, (2015) *Block User-Agent in htaccess for Apache Webserver*, *Ttias.be*. Available at: <https://ma.ttias.be/block-user-agent-in-htaccess-for-apache-webserver/> (Accessed: 20 November 2025).
57. Okta Trust, (2024) 'Okta Classic Application Sign-On Policy Bypass - Oct 4, 2024', *Okta Blog*, 24 October. Available at: <https://trust.okta.com/security-advisories/okta-classic-application-sign-on-policy-bypass-2024> (Accessed: 20 November 2025).
58. Group K (2023) *[CRITICAL] Vulnerability Notification: HPE Aruba Access Points Multiple Vulnerabilities (ARUBA-PSA-2023-009)*, *Group K*. Blogger. Available at: <https://www.group-k.be/2023/07/critical-vulnerability-notification-hpe.html> (Accessed: 20 November 2025).
59. Cloudflare (2025b) *Transform Rules*, *Cloudflare Docs*. Available at: <https://developers.cloudflare.com/rules/transform/> (Accessed: 20 November 2025).
60. PAN PSIRT (2025) *CVE-2025-4619 PAN-OS: Firewall Denial of Service (DoS) Using Specially Crafted Packets*, *Paloaltonetworks.com*. Available at: <https://security.paloaltonetworks.com/CVE-2025-4619> (Accessed: 20 November 2025).
61. Hackerone (2025) *Bypass of Cloudflare's Cache Keys and WAF via header overflow*, *Hackerone.com*. Available at: <https://hackerone.com/reports/3027461> (Accessed: 20 November 2025).

62. NHS (2025) *Active Exploitation of Zero-Day Vulnerability CVE-2024-55591 in FortiOS and FortiProxy*, NHS England. Available at: <https://digital.nhs.uk/cyber-alerts/2025/cc-4604> (Accessed: 20 November 2025).
63. Brown, K. (2022) *Supply Chain Conflicts of Interest Policy*. Available at: <https://www.heathrow.com/content/dam/heathrow/web/common/documents/company/doing-business-with-heathrow/procurement/policies/Supply-Chain-Conflicts-of-Interest-Policy.pdf> (Accessed: 20 November 2025).
64. IBM (2023) *What Are AI Hallucinations?*, IBM. Available at: <https://www.ibm.com/think/topics/ai-hallucinations> (Accessed: 21 November 2025).
65. Mollick, E. (2023) *How to... use ChatGPT to boost your writing*, www.oneusefulthing.org. Available at: <https://www.oneusefulthing.org/p/how-to-use-chatgpt-to-boost-your> (Accessed: 21 November 2025).

Appendix 1:

1. ****Internal Context:**

1.1 **Airline Specific Applications:**

- 1.1.1 **ARINC cMUSE:** Is Collins Aerospace company's next-generation common-use passenger processing system (CUPPS) solution, which allows multiple airlines to share their boarding gate positions and check-in desks to instead of having their own infrastructure at the Heathrow Airport (Collins Aerospace, 2025).
- 1.1.2 **FlightAware Version 5.8.0:** FlightAware is a global flight tracking and data service running on version 5.8.0 that helps Heathrow Airport keep a close eye on aircraft movements in real time. (FlightAware, 2023).
- 1.1.3 **Vanderlande Vibes version 7.0.0:** It is a Baggage Handling System Control Software which manages baggage routing and sorting across the terminals for Heathrow Airport (Vanderlande, 2015).

(Note: Access to these systems is protected using Multi-Factor Authentication (MFA) solution Okta, which ensure that only authorised personnel can interact with these applications.)

1.2 **Server Operating Systems**

- 1.2.1 **Red Hat Enterprise Linux (RHEL) version 8:** RHEL provides a flexible and stable foundation which allows Heathrow Airport to station applications and critical workloads quickly across physical servers with a consistent and secure operating experience (Red Hat, 2024).
At Heathrow, there are 2 RHEL servers for hosting 2 applications separately; ARINC cMuse & Vanderlande Vibes that in turn manages check-ins, baggage routing & weight balancing.
- 1.2.2 **Microsoft Windows Server 2022:** Due to its secure and modern server operating system designed for large-scale, enterprise-level workloads, Heathrow has deployed FlightAware in Microsoft Windows Server 2022 (Dell Technologies, 2022).
- 1.2.3 **Enterprise Apps & Payment Platform:**

- 1.2.4 Oracle Fusion Cloud ERP version 12.2.3:** Heathrow is using Oracle Fusion ERP to keep track of all the airport's financial transactions, managing assets, helping in processing invoices and payments & creating reports that Heathrow needs for regulators and financial audits (Oracle, 2024) (Lisa Dodson, 2024).
- 1.2.5 Oracle Fusion Cloud HCM version 12.2.6:** Oracle HCM or Human Capital Management is being used at Heathrow airport to keep track of everything related to its employees. It helps in managing like hiring, payroll & performance record (Oracle, 2024) (Drake, 2022).
- 1.2.6 Stripe Payment Gateway:** Heathrow Airport is using fully PCI-DSS compliant Stripe payment gateway for online payments. Stripe also supports refunds, fraud prevention control, real time payment monitoring all while encrypting the sensitive data (Stripe, 2025).

1.3 IOT & Network Infrastructure:

- 1.3.1 Hikvision CCTV camera:** Heathrow Airport is using Hikvision CCTV cameras, model DS-2CV2141G2-IDW built before 231108 for the whole area surveillance.
- 1.3.2 Cisco Catalyst 9300:** Heathrow has deployed Cisco Catalyst 9300 switches across data centres and terminals, linking systems like CCTV, Wi-Fi access points & workstations (Cisco, 2025).
- 1.3.3 Aruba Wireless (HPE) version 8.10.0.6:** Heathrow Airport is using Aruba Wireless Access Points from Hewlett Packard Enterprise, running on version 8.10.0.6 designed for large and busy environments. The Heathrow IT team monitors all the access points, troubleshoot issues and control the bandwidth. The traffic segmentation helps in isolating employee network, passenger Wi-Fi and IOT devices from each other for security reasons (Bailey, 2025) (HPE Aruba, 2025).

1.4 Security Devices:

- 1.4.1 Palo Alto Networks PAN-OS version 11.2:** It is a Next Generation Firewall that protects Heathrow's internal networks and control traffic between terminals, data centres, and third-party systems (Palo Alto, 2025).
- 1.4.2 Cloudflare Web Application Firewall (WAF):** Cloudflare protects Heathrow's public-facing websites, airline portals, and flight-information systems. Cloudflare WAF also provides real-time rule updates which automatically protects Heathrow Airport from any newly discovered vulnerabilities (Cloudflare, 2025).
- 1.4.3 Fortinet FortiProxy version 7.0.0 :** It is a secure web gateway used at Heathrow Airport to filter, monitor, and control the staff internet traffic. FortiProxy blocks any malicious sites, inspects the encrypted traffic, and prevents data leakage by enforcing Heathrow's acceptable-use and security policies (Fortinet, 2025).

1.5 Endpoint & Cloud:

- 1.5.1 Okta Multi Factor Authentication:** Okta MFA is being used in the Heathrow Airport IT infrastructure to add another protection layer by verifying user identities across Heathrow's applications and systems (Okta, 2025).
- 1.5.2 CrowdStrike Falcon version 7.20:** CrowdStrike Falcon Antivirus is installed at LHR workstations which keeps them safe as NGAV helps in anticipating known and unknown threats aiding in preventing it immediately (CrowdStrike, 2024).

1.6 Workstation OS:

- 1.6.1 Windows 11 Enterprise:** Heathrow Airport is using Windows 11 Enterprise across thousands of desktops used by staff in terminals, control rooms, and administrative offices (Microsoft, 2025).

2. **Information Security Basic Criteria:

Heathrow has adopted a structured risk management approach which is consistent with ISO/IEC 27001:2022 section 6.1.2 and ISO/IEC 27005:2022 section 6.4. The approach

establishes a firm set of criteria for evaluating, accepting, and treating information security risks.

3.1 Risk Management Approach:

The risk management approach ensures that risk can be identified, assessed and controlled, below are criteria to assess:

- **Likelihood criteria:** To assess how probable a risk event is.
- **Impact criteria:** To evaluate severity of consequences.
- **Risk acceptance:** This criteria is to determine whether risks are tolerable or not.
- **Availability of necessary resource:** The organization should assess if they have necessary resource to perform risk assessment and create a risk treatment plan (University of Hertfordshire, 2025). Also, to monitor the information security risk management process (University of Hertfordshire, 2025).

3.2 Likelihood Criteria:

Heathrow uses a five-level likelihood scale aligned with ISO/IEC 27005:2022 guidance to assess the probability of risk events occurring:

Likelihood	Description
5 - Almost certain	The risk source will most certainly reach its objective by using one of the considered methods of attack. The likelihood of the risk scenario is very high.
4 - Very likely	The risk source will probably reach its objective by using one of the considered methods of attack. The likelihood of the risk scenario is high.
3 - Likely	The risk source is able to reach its objective by using one of the considered methods of attack. The likelihood of the risk scenario is significant.
2 - Rather unlikely	The risk source has relatively little chance of reaching its objective by using one of the considered methods of attack. The likelihood of the risk scenario is low.
1 - Unlikely	The risk source has very little chance of reaching its objective by using one of the considered methods of attack. The likelihood of the risk scenario is very low.

Figure 1: Likelihood Scale (ISO/IEC 270005:2022, p42)

3.3 Impact/Consequence criteria:

Heathrow evaluates impact based on the five-level consequence scale specified in ISO/IEC 27005:2022. This scale helps in evaluating how much cost or damage an information security event could cause to the organisation:

Consequences	Description
5 – Catastrophic	Sector or regulatory consequences beyond the organization Substantially impacted sector ecosystem(s), with consequences that can be long lasting. And/or: difficulty for the State, and even an incapacity, to ensure a regulatory function or one of its missions of vital importance. And/or: critical consequences on the safety of persons and property (health crisis, major environmental pollution, destruction of essential infrastructures, etc.).
4 – Critical	Disastrous consequences for the organization Incapacity for the organization to ensure all or a portion of its activity, with possible serious consequences on the safety of persons and property. The organization will most likely not overcome the situation (its survival is threatened), the activity sectors or state sectors in which it operates will likely be affected slightly, without any long-lasting consequences.
3 – Serious	Substantial consequences for the organization High degradation in the performance of the activity, with possible significant consequences on the safety of persons and property. The organization will overcome the situation with serious difficulties (operation in a highly degraded mode), without any sector or state impact.
2 – Significant	Significant but limited consequences for the organization Degradation in the performance of the activity with no consequences on the safety of persons and property. The organization will overcome the situation despite a few difficulties (operation in degraded mode).
1 – Minor	Negligible consequences for the organization No consequences on operations or the performance of the activity or on the safety of persons and property. The organization will overcome the situation without too much difficulty (margins will be consumed).

Figure 2: Likelihood scale (ISO/IEC 270005:2022, p41)

3.4 Risk Evaluation Criteria:

To judge whether a risk is acceptable or needs action, Heathrow checks each risk against a set of criteria. This includes:

- How important the information or system is.
- Whether any laws or contracts apply.
- How much Heathrow relies on the system working properly.
- What stakeholders expect.
- How the issue could harm Heathrow's reputation.

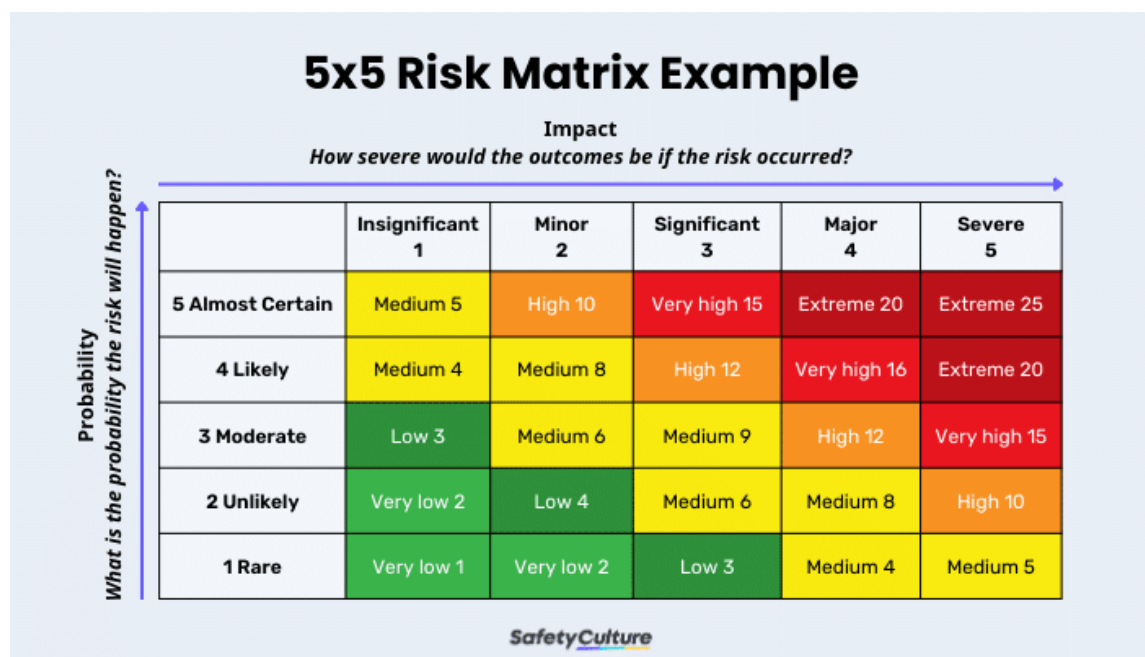


Figure 3: Color-coded 5x5 risk assessment matrix (SafetyCulture 2022)

Likelihood	Consequence				
	Catastrophic	Critical	Serious	Significant	Minor
Almost certain	Very high	Very high	High	High	Medium
Very likely	Very high	High	High	Medium	Low
Likely	High	High	Medium	Low	Low
Rather unlikely	Medium	Medium	Low	Low	Very low
Unlikely	Low	Low	Low	Very low	Very low

Figure 4: Qualitative approach to risk criteria (ISO/IEC 270005:2022, p43)

3.5 Risk Acceptance Criteria:

Risk acceptance criteria at Heathrow are developed considering the following:

- **Business criteria:** Strategic value, competitive positioning and operational needs.
- 3.6 **Legal and regulatory aspects:** Compliance obligations and penalties for non-compliance.
- 3.7 **Operational factors:** Impact on critical airport functions and service continuity.
- 3.8 **Technology:** Technical feasibility of control implementation and system dependencies.
- 3.9 **Financial:** Cost of risk treatment vs. potential loss and any budget constraints.
- 3.10 **Social and humanitarian factors:** Impact on passenger safety, public reputation and community trust.

Senior management approval is required for any risk acceptance decision outside normal parameters, with documented justification explaining why the risk is tolerable.

Level of risk	Risk evaluation	Description
Low (green)	Acceptable as is	The risk can be accepted without further action.
Moderate (amber)	Tolerable under control	A follow-up in terms of risk management should be conducted and actions should be set up in the framework of continuous improvement over the medium and long term.
High (red)	Unacceptable	Measures for reducing the risk should absolutely be taken in the short-term. Otherwise, all or a portion of the activity should be refused.

Figure 5: Risk Acceptance scale (ISO/IEC 270005:2022, p46)

4. **Threat Landscape:** Heathrow Airport faces many cybersecurity threats, following are the list:
- 4.1 **Supply Chain Attack:** Hackers often tend to target the third party suppliers which directly impacts the Heathrow Airport like what happened with the September 2025 Collins Aerospace attack due to which many airlines were forced to go back to manual check-in and people had to wait in queue for hours and hours leading to many people missing their flights (Davies, Heyndyk and Tidy, 2025). Dependency on supplier systems have made this the biggest risk now.
- 4.2 **Ransomware:** Attackers can encrypt LHR's computer systems and demand payment to decrypt them. If this happens, critical operations like check-in desks, baggage systems, or fuel management could stop working which can lead operational halt (PureCyber, 2025).
- 4.3 **Insider Threats:** LHR's employees or contractors either by accident or deliberately can compromise the security. For example, they could click on phishing emails. Use Public Wi-Fi or share their passwords (PureCyber, 2025).
- 4.4 **Phishing Attack:** Hackers often target employees using email phishing/scam attacks by sending fake emails pretending to be from Heathrow or government agencies, asking the

staff for passwords or payment information. The NCSC (National Cyber Security Centre) reports that scammers regularly target UK airports using fake gov.uk email addresses and the finance and IT staffs are very common targets (PureCyber, 2025).

- 4.5 **DDOS Attack:** Distributed Denial of Service Attack, in this Hackers can flood the Heathrow's website, online booking systems and flight information displays with massive traffic from thousands of botnets (computers). This causes the systems to crash or become unavailable which will prevent passengers from accessing any of these systems (PureCyber, 2025).

5. **Organisational Responsibilities and Governance:**

As per ISO standard 27001 clause 5.3 and ISO 27005 clause 6.1, below are the roles and responsibilities:

- 5.1 **Board and Committee Responsibilities:** The HAHL Board oversees Heathrow's risk management system and checks if the risk response processes are working properly or not. The two board committees which are 1) The **Audit Committee** who reviews financial and operational controls and the 2) **Sustainability and Operational Risk Committee (SORC)** who reviews cyber security strategy, cyber incidents and mitigations; oversees the risk for LHR (Heathrow Airport Holdings Limited, 2024, p. 101; p. 121).

The **Risk and Assurance Committee** is a subcommittee of the Executive Committee who meets quarterly to collaborate and review any crucial risks including cybersecurity risk. Risks are then escalated to the Executive Committee which is then reviewed by the Audit Committee and SORC for independent review and finally approved by HAHL Board on quarterly basis (Heathrow Airport Holdings Limited, 2024).

- 5.2 **Risk Management Framework:** Heathrow's Risk and Assurance Management Framework is embedded Group-wide to identify, mitigate, review, and report risks. Heathrow checks each risk against its annual risk appetite levels to make sure decisions stay consistent with the company's goals. (Heathrow Airport Holdings Limited, 2024).

- 5.3 **Chief Information Officer Security Officer (CISO):** CISO is the main person who is responsible for Heathrow's information security programme. The CISO reports to senior management and works with the Risk and Assurance Committee to oversee cybersecurity strategy, risk management, and incident handling. The CISO ensures that information security policies and controls are implemented across the entire organisation and that security risks are escalated appropriately to the Board (Heathrow Airport Holdings Limited, 2024).

Day to day information security responsibilities are distributed across operational teams under the CISO overseeing it.

- 5.4 **IT Security Staff:** They find security weaknesses in systems and implements security controls. They also test the systems for any vulnerabilities and respond to security incidents.
- 5.5 **Procurement and Suppliers Management:** This team interviews and approves suppliers before they work for Heathrow Airport. They include the security requirements in contracts and monitor if suppliers are following security rules or not (Heathrow Airport Holdings Limited, 2024).
- 5.6 **Legal and Compliance Team:** They interpret the laws and regulations like GDPR, Data Protection Act to ensure contracts have the right security terms.
- 5.7 **Operations Team:** The operations team identify which systems are the most critical to airport operations and assess if the security solutions are practical and would not disrupt the services (Heathrow Airport Holdings Limited, 2024).

Each business unit leader is responsible for managing risks in their area and implementing

assigned risk solutions. For example, the head of baggage operations is responsible for security of the baggage handling system.

Appendix 2: Refer the attached Risk Assessment Excel sheet.

Appendix 3:

Commentary:

Iteration #	Prompt/Command/Request to the tool agreed with your tutor (eg. ChatGPT)	Output generated by the tool agreed with your tutor (eg. ChatGPT)	Missing information/changes required for the next iteration
1	Hi ChatGPT, I need your help with Information Security within supplier agreements Policy creation. Can you act as a CISO for an Airport and create a policy related to supplier agreements? The policy should address CIA for airport operational systems and passenger data. Kindly follow the ISO 27001 and GDPR in creating this policy. In order to not disclose any confidential data, I would request you to take any airport as a placement, which I can later edit to add the actual data in my report. But before you start, can you suggest to me the Policy headers we can use?	Absolutely — acting as a CISO for an airport, I can help you create a solid structure for an Information Security within Supplier Agreements Policy aligned with ISO/IEC 27001, GDPR, and focused on CIA (Confidentiality, Integrity, Availability) of operational systems and passenger data. Here are recommended Policy Headers / Structure: 📌 Information Security within Supplier Agreements Policy — Proposed Structure Purpose Scope Objectives Definitions & Terminology Roles and Responsibilities Regulatory & Standards Compliance - ISO/IEC 27001 - GDPR - Local Aviation & Cyber Regulations (placeholder)	

		7. Supplier Classification ○ Critical vs Non-critical Suppliers ○ Data Processing Categories (e.g., passenger data) 8. Risk Assessment & Due Diligence ○ Pre-engagement evaluation ○ Ongoing risk monitoring 9. Information Security Requirements for Suppliers ○ CIA Controls for systems and data ○ Security controls aligned with Annex A of ISO 27001 10. Data Protection Requirements ○ GDPR principles ○ Data Processing Agreements (DPAs) ○ Data retention, access, and transfer requirements 11. Access Control & Network Connectivity 12. Incident Management & Breach Notification 13. Business Continuity & Disaster Recovery 14. Monitoring, Auditing & Compliance Reviews 15. Subcontractor Requirements 16. Termination of Contracts / Offboarding 17. Confidentiality & Intellectual Property	
--	--	---	--

		18. Document Control & Revision History ✿ Optional sections (if needed) • Supplier Security Awareness & Training • Performance Metrics & KPIs • Enforcement & Sanctions • Exceptions Management	
2	Can you consider any United Kingdom airport in order to follow any regulations which are followed in that country so that our Policy is created as per the UK standard?	☐ UK General Data Protection Regulation (UK GDPR) and Data Protection Act 2018 for data protection compliance. GOV.UK+2Wikipedia+2 ☐ Alignment with ISO/IEC 27001 (information security management) to address confidentiality, integrity and availability (CIA) of operational and passenger-data systems. ☐ Consideration of aviation-specific contractual requirements for airports (for example, one UK airport's supplier terms reference data protection compliance explicitly).	Policy statement section is missing (Brown, 2022).
3	Policy statement section is missing in the policy headers	Information Security within Supplier Agreements Policy — Updated Structure (UK Airport) 1. Purpose 2. Scope 3. Policy Statement ← <i>(newly included)</i> 4. Objectives 5. Definitions & Terminology 6. Roles and Responsibilities 7. Regulatory & Standards Compliance ○ ISO/IEC 27001	

		○ UK GDPR & Data Protection Act 2018 ○ UK Civil Aviation Authority (CAA) Cyber Security Principles ○ NIS Regulations (if applicable) 8. Supplier Classification ○ Critical vs Non-critical Suppliers ○ Access to Operational Systems & Passenger Data 9. Risk Assessment & Due Diligence ○ Security risk evaluation before onboarding ○ Continuous risk monitoring 10. Information Security Requirements for Suppliers ○ CIA controls for airport systems ○ Annex A ISO 27001 aligned controls ○ Secure software/service development requirements 11. Data Protection & Privacy Requirements ○ Data Processing Agreements (DPAs) ○ Data sovereignty, retention & transfer controls ○ Breach reporting in compliance with UK GDPR timelines 12. Access Control & Network Security 13. Incident Management & Reporting	
--	--	--	--

		14. Business Continuity & Disaster Recovery Requirements 15. Monitoring, Audit & Compliance Reviews 16. Subcontractor & Third-Party Cascade Requirements 17. Contract Termination & Offboarding Controls 18. Confidentiality & Intellectual Property Protection 19. Security Awareness for Suppliers 20. Exceptions Management 21. Document Control & Revision History	
4	Below are my policy statements for assets which I created while doing risk assessment. Create the policy based on this. And word limit should be maximum 3 pages/1500 words. 1) Privileged access rights must be given strictly on the principle of least privilege and role-based access control. Privileged accounts shall be reviewed quarterly and immediately deleted when no longer in use. 2) All FlightAware systems must be kept fully updated and patched to prevent service disruption and ensure continuation of operation. 3) Before storage and display all input handled by VIBES webservices must be	Absolutely — thank you for sharing these security control statements. I have now incorporated them appropriately into the correct sections of the final policy, aligned with: ✓ ISO/IEC 27001 ✓ UK GDPR & Data Protection Act 2018 ✓ UK Airport operational security (operational tech + passenger data) ✓ CIA triad (Confidentiality, Integrity, Availability) Below is the 3-page / approx. 1500-word policy draft with placeholders where needed (e.g., [Airport Name]). Information Security within Supplier Agreements Policy Version 1.0 [Airport Name] United Kingdom 1. Purpose This policy ensures that suppliers supporting [Airport Name] operations implement	

validated and sanitized to prevent XSS exploitation. 4) Systems must be configured to disable vulnerable kernel modules or must be patched in order to prevent privilege escalation to protect system integrity. 5) Ensure that only the management hosts and Microsoft Update servers that are explicitly required have access to your WSUS infrastructure. For all other connections, it is strongly recommended that inbound traffic be blocked to TCP ports 8530 and 8531. 6) All or any public-facing application endpoints must be restricted or disabled when not required to prevent unauthorized access and remote exploitation. 7) To ensure user only access necessary data for their job responsibilities, all the Oracle products must enforce strict session management and role based access controls. 8) Cryptographically secure nonce (number-used-once) values should be implemented for all sensitive transactions and API requests. 9) All CCTV cameras must be isolated from external networks, regularly patched, and protected using secure firewall segmentation to	appropriate information security measures to protect airport operational systems and passenger data. The associated controls preserve confidentiality, integrity, and availability (CIA) in alignment with ISO/IEC 27001, UK GDPR, and UK Civil Aviation Authority cyber principles. 2. Scope This policy applies to all third-party suppliers, vendors, contractors, cloud service providers, and subcontractors who: • Access or process airport passenger data or employee data. • Provide or support systems related to airport operations (including flight-tracking, CCTV, ticketing, baggage systems, identity management, operational technology). 3. Policy Statement [Airport Name] requires all supplier agreements to include enforceable security obligations that ensure systems, networks, and personal data managed or accessed by suppliers remain protected from unauthorized access, disclosure, alteration, or loss. 4. Objectives • Maintain resilience of airport critical services. • Protect personal data in accordance with UK GDPR. • Minimize cybersecurity and operational vulnerabilities arising from supplier services. • Ensure continuous compliance and risk management throughout the supplier lifecycle.	
---	---	--

prevent unauthorised access to surveillance systems. 10) All affected devices should be identified, assessed, and remediated through timely software updates, strict access controls, and enforcement of physical security measures 11) CLI and web- based management interfaces should be accessible to only authorized administrative networks and should be isolated within layer-2 management vlan. 12) Network level protection like adequate firewall rules and ACL should be applied to reduce attack surface. 13) Cloudflare Transform Rules should be implemented to remove, rewrite, or whitelist only approved and trusted HTTP headers, ensuring that attacker-controlled ambiguous, duplicate, or headers cannot influence WAF logic or cache behavior. 14) Organization should implement strict access controls in administrative interfaces of FortiProxy systems. The HTTP/HTTPS management interface must be available to approved IP addresses only. 15) All authentication systems must enforce strong MFA validation, apply user behaviour analytics, and block access attempts from	5. Regulatory & Standards Compliance Suppliers must comply with: • ISO/IEC 27001 & Annex A security controls • UK GDPR & Data Protection Act 2018 • UK NIS Regulations (where applicable) • CAA Cyber Security Strategy & aviation operational resilience guidelines • Contractual requirements of <i>[Airport Name]</i> 6. Roles & Responsibilities • Head of Cyber Security / CISO — oversight and enforcement of supplier security. • Procurement Team — ensures contractual inclusion of security clauses. • Supplier Managers — ongoing monitoring of third-party compliance. • Suppliers — implement and maintain agreed security controls. 7. Supplier Security Requirements Suppliers must enforce strict CIA-focused controls, including but not limited to: 7.1 Access Control & Privileged Account Protection • Privileged access must follow least privilege and RBAC principles.	
---	---	--

	untrusted devices or unknown user agents to prevent unauthorised sign-on attempts. 16) All security monitoring systems must use encryption mechanisms and enforce strong protections against eavesdropping to ensure secure communication. 17) All OS must be patched promptly and features such as virtualization must be managed to avoid privilege escalation vulnerabilities.	• Privileged accounts reviewed quarterly and revoked upon role change or contract end. • Only authorized administrative networks may access CLI and web-based management interfaces; isolation must be maintained within dedicated Layer-2 management VLANs. • Strong MFA required for all authentication systems, including enforcement of user-behaviour risk analytics and restriction of untrusted devices. 7.2 System Security & Patch Management Suppliers responsible for airport-related systems must: • Ensure all operational systems — including FlightAware system implementations — remain securely patched and updated. • Patch all operating systems promptly and manage virtualization components to prevent privilege escalation. • Disable or patch vulnerable kernel modules to maintain platform integrity. • Timely remediation of affected devices with physical and logical access controls. 7.3 Network & Infrastructure Security • WSUS infrastructure must only be accessible to designated management hosts and approved Microsoft update servers. Block all inbound traffic to TCP 8530 / 8531 from unauthorized sources.	
--	--	--	--

		• Adequate firewall and access control lists (ACLs) must be enforced to reduce network attack surface. • CCTV and surveillance systems must be completely isolated from public networks, segmented by secure firewalls, and regularly patched. 7.4 Application Security Suppliers developing or hosting public-facing airport applications must: • Restrict or disable endpoints that are unnecessary or unused to reduce remote exploitation risk. • Validate and sanitize all input received by web services (e.g., VIBES system) before storage or display to prevent XSS attacks. • Implement secure cryptographic nonces for all sensitive transactions and API communications. • Cloudflare Transform Rules must be enforced (where used) to whitelist trusted HTTP headers and prevent attacker-controlled header manipulation. 7.5 Data Protection & GDPR Compliance Suppliers processing or accessing passenger personal data must: • Sign Data Processing Agreements (DPAs) and comply with UK GDPR Articles 5, 32, and 44–49. • Limit data access to job necessity and enforce strict session management and RBAC for Oracle-based systems. • Implement controls to maintain data integrity throughout processing.	
--	--	---	--

		• Encrypt data-in-transit, especially security monitoring and administrative systems, to prevent eavesdropping. • Follow airport retention, secure transfer, and safe disposal rules. 8. Business Continuity & Operational Resilience Suppliers must: • Ensure their services support uninterrupted airport operations. • Maintain tested business continuity and disaster recovery capabilities. • Provide incident response cooperation and restore services within airport-defined SLAs. 9. Incident Reporting Suppliers must: • Report suspected or confirmed cybersecurity events involving airport data or systems within 24 hours. • Notify <i>[Airport Name]</i> of any personal data breach in accordance with UK GDPR notification obligations. 10. Audit & Monitoring <i>[Airport Name]</i> reserves the right to: • Conduct periodic security assessments, audits, and technical reviews.	
--	--	---	--

		• Request evidence of security compliance including penetration test reports, access reviews, and risk logs. • Suspend access or terminate services if supplier introduces unacceptable risk. 11. Subcontractor Management Suppliers must: • Obtain written approval before subcontracting operational or data-related services. • Ensure subcontractors comply fully with this policy using cascaded security clauses. • Remain accountable for subcontractor behaviour and risk. 12. Contract Termination & Offboarding Upon contract expiry or termination: • All airport data must be returned or securely destroyed. • Logical and physical access rights must be revoked immediately. • Offboarding must be documented and verified by airport security representatives. 13. Exceptions Management Any exception to this policy must be approved in writing by the CISO and assessed for residual risk. 14. Enforcement Breaches of this policy may result in:	
--	--	---	--

		• Contract termination • Legal action • Supplier disqualification from future agreements 15. Document Control <table><tr><td>Version</td><td>Date</td><td>Description</td><td>Owner</td></tr><tr><td>1.0</td><td>[Initials]</td><td>Release</td><td>CI/Security</td></tr></table> ✓ Summary of Key Airport-Relevant Assets Covered <table><tr><td>Asset Type</td><td>Relevant Controls Covered</td></tr><tr><td>Operational Tech (CCTV, WSUS, FlightAware)</td><td>Network isolation, patching, hardening</td></tr><tr><td>Passenger Data Systems (Oracle, apps)</td><td>GDPR controls, RBAC, MFA</td></tr><tr><td>Web & API services (VIBES,</td><td>Input validation, secure headers,</td></tr></table>	Version	Date	Description	Owner	1.0	[Initials]	Release	CI/Security	Asset Type	Relevant Controls Covered	Operational Tech (CCTV, WSUS, FlightAware)	Network isolation, patching, hardening	Passenger Data Systems (Oracle, apps)	GDPR controls, RBAC, MFA	Web & API services (VIBES,	Input validation, secure headers,	
Version	Date	Description	Owner																
1.0	[Initials]	Release	CI/Security																
Asset Type	Relevant Controls Covered																		
Operational Tech (CCTV, WSUS, FlightAware)	Network isolation, patching, hardening																		
Passenger Data Systems (Oracle, apps)	GDPR controls, RBAC, MFA																		
Web & API services (VIBES,	Input validation, secure headers,																		

		Cloudflare cryptography) Privileged Admin Infrastructure access control, VLAN isolation Monitoring & Security Tools Encrypt ion, secure channels	
5	You didn't incorporate the policy statements I gave you and did you consider the policy statements when creating this policy?	Information Security within Supplier Agreements Policy [Airport Name] – United Kingdom 1. Purpose The purpose of this policy is to ensure that all suppliers supporting [Airport Name] implement appropriate information security controls to protect airport operational systems and passenger data, in line with the confidentiality, integrity and availability (CIA) principles, ISO/IEC 27001 and UK GDPR. 2. Scope This policy applies to all third-party suppliers, vendors, contractors, managed service providers and their subcontractors who: • Provide, host, manage or support airport operational systems, including but not limited to FlightAware, VIBES, WSUS, Oracle products, CCTV systems, and FortiProxy. • Access, process or store passenger data, staff data, or security monitoring data on behalf of [Airport Name]. 3. Policy Statement	

		[Airport Name] requires that information security and data protection requirements are formally embedded into all supplier agreements. Suppliers must implement technical and organisational measures that protect airport systems and personal data against unauthorised access, alteration, loss or disruption, and must enable [Airport Name] to demonstrate compliance with ISO/IEC 27001 and UK GDPR. 4. Regulatory and Standards Compliance Suppliers must comply with, at a minimum: • ISO/IEC 27001 and relevant Annex A controls. • UK GDPR and the Data Protection Act 2018. • Applicable UK aviation, cybersecurity and critical infrastructure regulations. Where suppliers act as processors under UK GDPR, a Data Processing Agreement (DPA) must be in place. 5. Roles and Responsibilities • CISO / Head of Cyber Security: Owns this policy, defines control requirements for suppliers and oversees compliance. • Procurement: Ensures supplier contracts include mandatory security clauses and references to this policy. • Business Owners / Supplier Managers: Ensure suppliers implement agreed controls and support reviews and audits. • Suppliers: Implement and maintain all agreed security and data protection controls, including those set out below. 6. Security Requirements for Suppliers	
--	--	---	--

		6.1 Access Control and Privileged Accounts 1. Privileged Access Rights ○ Privileged access rights must be granted strictly on the principle of least privilege and role-based access control (RBAC). ○ Privileged accounts shall be reviewed at least quarterly and immediately deleted or disabled when no longer required (e.g., role change, contract termination). <i>(Statement 1)</i> 2. Session and Role Management (Oracle Products) ○ All Oracle products used in connection with [Airport Name] must enforce strict session management and RBAC, ensuring users can access only the data necessary for their job responsibilities. <i>(Statement 7)</i> 3. Administrative Interfaces ○ CLI and web-based management interfaces for infrastructure, network devices and security appliances must be accessible only from authorised administrative networks and isolated within a dedicated Layer-2 management VLAN. <i>(Statement 11)</i> ○ Administrative interfaces for FortiProxy systems must be restricted so that HTTP/HTTPS management access is available only from approved IP addresses and tightly controlled. <i>(Statement 14)</i> 4. Strong Authentication and MFA	
--	--	--	--

		○ All authentication systems used by suppliers to access airport systems must enforce strong multi-factor authentication (MFA), apply user behaviour analytics where feasible, and block access attempts from untrusted devices or unknown user agents to prevent unauthorised sign-on attempts. <i>(Statement 15)</i> 6.2 System Hardening, Patch and Vulnerability Management 5. Operational Systems and FlightAware ○ All FlightAware systems and associated components must be fully updated and patched in a timely manner to prevent service disruption and ensure continuation of airport operations. <i>(Statement 2)</i> 6. Operating Systems and Kernel Modules ○ All operating systems must be patched promptly following vendor guidance and risk assessment, and virtualisation features must be configured securely to avoid privilege escalation vulnerabilities. <i>(Statement 17)</i> ○ Systems must be configured to disable vulnerable kernel modules or ensure they are patched to prevent privilege escalation and protect system integrity. <i>(Statement 4)</i> 7. Vulnerable or Affected Devices ○ All affected devices identified via vulnerability management, advisories or incident response must be identified, assessed and remediated through timely	
--	--	---	--

		software updates, strict access controls, and enforcement of physical security measures. <i>(Statement 10)</i> 6.3 Network and Infrastructure Security 8. WSUS Infrastructure Protection ○ Only management hosts and Microsoft Update servers explicitly required for operations may access WSUS infrastructure. ○ For all other connections, inbound traffic must be blocked to TCP ports 8530 and 8531 or other WSUS ports, to prevent unauthorised access or tampering. <i>(Statement 5)</i> 9. Firewalling and ACLs ○ Suppliers must implement adequate network-level protections, including firewalls and access control lists (ACLs), to minimise the exposed attack surface for systems supporting [Airport Name]. <i>(Statement 12)</i> 10. CCTV and Surveillance Networks • All CCTV cameras and surveillance systems that support [Airport Name] must be isolated from external networks, regularly patched, and protected by secure firewall segmentation to prevent unauthorised access to surveillance systems and recordings. <i>(Statement 9)</i> 6.4 Application and Web Security 11. Input Validation (VIBES Web Services) • Before storage and display, all input handled by VIBES web services must be validated and sanitised to prevent	
--	--	---	--

cross-site scripting (XSS) and related injection attacks. *(Statement 3)*

12. Public-facing Endpoints

- **All public-facing application endpoints managed by suppliers for [Airport Name] must be restricted, locked down, or disabled when not required, to prevent unauthorised access and remote exploitation. *(Statement 6)***

13. Cryptographic Nonces and Sensitive Transactions

- **Suppliers must implement cryptographically secure nonce values for all sensitive transactions and API requests, to protect against replay and request-forgery attacks. *(Statement 8)***

14. Cloudflare Transform Rules and HTTP Headers

- **Where Cloudflare or similar services are used, Transform Rules must be implemented to remove, rewrite, or whitelist only approved and trusted HTTP headers.**
- **Attacker-controlled ambiguous, duplicate or unauthorised headers must not influence WAF logic or cache behaviour. *(Statement 13)***

6.5 Security Monitoring and Communications Protection

15. Monitoring Systems and Encryption

- **All security monitoring systems and associated interfaces must use strong encryption mechanisms and enforce protections against eavesdropping, ensuring the confidentiality and integrity of monitoring data in transit. *(Statement 16)***

		7. Data Protection and Privacy (UK GDPR) Suppliers that process personal data on behalf of [Airport Name] must: • Process data only on documented instructions from [Airport Name]. • Implement the technical and organisational measures defined in this policy and associated DPAs. • Support data subject rights, breach notification, and data retention/disposal requirements under UK GDPR. • Ensure that access controls in Sections 6.1 and 6.4 are applied to passenger and staff data to maintain confidentiality and integrity. 8. Business Continuity and Incident Management • Suppliers must maintain business continuity and disaster recovery capabilities that are appropriate to the criticality of the service. • Security incidents, including suspected personal data breaches or compromises of systems referenced in this policy, must be reported to [Airport Name] without undue delay and in time to meet regulatory notification obligations. 9. Audit, Monitoring and Compliance • [Airport Name] reserves the right to assess, audit or request evidence of the controls described in this policy, including configuration records, access reviews, and vulnerability management reports.	
--	--	---	--

		• Failure to provide sufficient assurance may result in risk treatment actions, up to and including suspension of services. 10. Subcontractors • Suppliers must not engage subcontractors for services related to airport systems or data without prior written approval from [Airport Name]. • Approved subcontractors must be bound by equivalent contractual obligations, including all security requirements set out in this policy. 11. Exceptions Any deviation from this policy must be formally documented, risk-assessed, and approved in writing by the CISO or delegate before implementation. 12. Enforcement and Review Non-compliance with this policy may result in contractual penalties, suspension or termination of supplier agreements, and may be reported to regulatory authorities where required. This policy shall be reviewed at least annually, or following significant changes to regulations, airport operations, or supplier risk.	
6	Let me give you a generic example you can refer for refining this policy. Information security policy in practice - Remote Access Policy (a generic example) isp-impl.png	 Here's what I'll do now I will refine the previous Supplier Security Policy to: ◆ Include an Organisational Context section (policy stance: Cautious–Strict for an airport) ◆ Describe a Policy Development Team ◆ Include assets from your risk assessment and why they matter ◆ Explain risks tied to those assets	

Develop and policy team Your policy team needs to reach the full depth and breadth of the organisation. Obviously, it depends upon the size of your organisation but typically it'll include 5-10 people. For smaller organisations, perhaps 1 person with a contracted security consultant would suffice.	◆ Add a section for audit practices and incident response contacts ◆ Expand policy violations section to fit expectations ◆ Keep your 17 technical controls directly embedded ◆ Keep the content aligned with UK GDPR and ISO 27001 ◆ Ensure the total length is still within 3 pages / ~1500 words	
Members typically include: Senior administrator	 Information Security in Supplier Agreements Policy (Aligned to UK Airport Requirements) Version 1.1 – [Airport Name]	
Legal staff Employee representative (perhaps a member of staff or union representative) Senior member of IT Someone with decent writing skills to edit/structure the policy (surprisingly important!) Determine organisational context and overall approach to security There are two overall approaches to security policies we can take: restrictive and permissive.	 Policy Development Team This policy has been developed by the Information Security Team in collaboration with: • Senior Administration Representative • Legal & Procurement Representatives • IT Security Architect • Operational Technology (OT) Lead • Data Protection Officer (DPO) • Employee/Union Representative • Technical Writer / Policy Editor They ensure cross-departmental understanding and effective implementation.	
Restrictive policies restrict what a user can do or use. For example, it may restrict		

the use of outside laptops to connect to the WiFi or it may restrict actions on a computer. Permissive policies give users permission to do something. For example, it permits users to bring in their own devices and connect them to WiFi. Organisations can have specific security stances that range from fully open and receptive to paranoid.	2 Organisational Context & Security Approach <i>[Airport Name]</i> is classified as critical national infrastructure (CNI). This policy therefore applies a strict and restrictive security stance, where: Access to airport operational systems and passenger data is prohibited by default unless explicitly approved through validated business need. This is required to maintain safe airport operation and public trust.											
Open Optimistic Cautious Strict Paranoid Identify assets to be protected This is very much part of your risk assessment and risk management strategies. Here are some examples of assets, broken down into asset types: Physical assets Actual hardware devices Logical assets	3 Asset Overview & CIA Protection Supplier-supported assets include: <table><thead><tr><th>Asset Type</th><th>Examples</th></tr></thead><tbody><tr><td>Physical assets</td><td>CCTV cameras, network equipment</td></tr><tr><td>Network assets</td><td>Firewalls, WSUS, Fortinet, Cloudflare</td></tr><tr><td>System assets (IT & OT)</td><td>Oracle databases, Flight information systems</td></tr><tr><td>Information assets</td><td>Passenger data, user credentials</td></tr></tbody></table> Loss or compromise may result in: - Aircraft operational disruption - Passenger data breaches (UK GDPR violation) - Safety & reputational impacts - Regulatory penalties issued by the UK CAA or ICO	Asset Type	Examples	Physical assets	CCTV cameras, network equipment	Network assets	Firewalls, WSUS, Fortinet, Cloudflare	System assets (IT & OT)	Oracle databases, Flight information systems	Information assets	Passenger data, user credentials	
Asset Type	Examples											
Physical assets	CCTV cameras, network equipment											
Network assets	Firewalls, WSUS, Fortinet, Cloudflare											
System assets (IT & OT)	Oracle databases, Flight information systems											
Information assets	Passenger data, user credentials											

Digital information that can be viewed and misused Network assets Routers, cables, bastion hosts, servers, firewall hardware and software System assets Software that runs the system (e.g., server software and applications) Determine what should be audited for security Identify security risks Again, this will form part of your risk assessment, so you need to specify the kinds of risk and attacks to be guarded against. E.g. Denial of service attack Disclosure of information due to fraud Unauthorised access Acceptable use policy (AUP) Define acceptable computing and communications practices on the part of employees and business partners. Typically, it is simpler to define what is “unacceptable use” and the consequences therein.	Therefore, suppliers must apply strong protections aligned to ISO/IEC 27001. 4 Security Risk Alignment Supplier agreements must protect against: • Unauthorised access (internal/external) • Disclosure of passenger data • Privilege escalation in OT and IT systems • Denial-of-service attacks targeting airport operations • Exploitation of unpatched vulnerabilities • Interception of security monitoring or admin channels These risks are mapped directly to the 17 mandatory supplier controls (embedded in Section 6). 5 Policy Purpose To ensure that all supplier agreements enforce robust information security controls to maintain the confidentiality, integrity and availability of [Airport Name] systems and data. 6 Scope This policy applies to all suppliers involved in: • OT & IT system hosting, maintenance or development • Personal data processing under UK GDPR	
---	--	--

	Example AUPs https://www.nspcc.org.uk/globalassets/documents/volunteering/essential-resources-for-volunteers/isms-aup.pdfLinks to an external site. https://www.bath.ac.uk/corporate-information/it-acceptable-use-policy/Links to an external site. https://www.gov.uk/government/publications/acceptable-use-policy-jsp-740Links to an external site. https://assets.publishing.service.gov.uk/government/uploads/system/uploads/attachment_data/file/839545/dwp-acceptable-use-policy.pdfLinks to an external site. https://www.exeter.ox.ac.uk/policies/0007_Acceptable_Use.pdfLinks to an external site. https://www.nhsbsa.nhs.uk/sites/default/files/2017-05/nhsbsa-acceptable-use-	• Network security and infrastructure management • Security monitoring and support services 7 Policy Statements & Required Controls <i>(All 17 of your statements integrated below)</i> 7.1 Privileged Access & Authentication Security • Privileged access rights must follow least privilege + RBAC and be reviewed quarterly. <i>(1)</i> • Accounts removed immediately upon job/contract change. <i>(1)</i> • Oracle systems must enforce secure session and role management. <i>(7)</i> • MFA and behavioural monitoring required for all authentication systems. <i>(15)</i> 7.2 System Hardening & Patch Management • FlightAware systems must remain fully patched and operational. <i>(2)</i> • OS platforms patched promptly; virtualisation hardened. <i>(17)</i> • Disable or patch vulnerable kernel modules to prevent privilege escalation. <i>(4)</i> • All affected devices must undergo assessment + timely remediation & physical access controls. <i>(10)</i> 7.3 Network & Infrastructure Security • WSUS reachable only by approved management hosts & Microsoft servers; block ports 8530/8531. <i>(5)</i>	
--	---	---	--

policy.pdfLinks to an external site. Define remote access policy If past years have taught us anything, it's the importance of being able to work from home with little notice. A good remote access policy "defines and states the rules and requirements for accessing the company's network. Rules must be defined to eliminate potential exposure due to unauthorised use" (any-ref-from-book, 2019) The policy needs to define access and any controls. For example, acceptable protocols such as Telnet (ahem) or SSH. Be specific in how people connect, never assume knowledge. Do they need a bespoke VPN application, for example? Is that VPN cross-platform compatible? You may also need users to install antivirus and have a software firewall on their own, personal laptop. Violations of policy Remember we live in a society of 'innocent until proven guilty' (hard to believe sometimes, I know). Unsurprisingly, a policy is needed for violations of policy. Most of the time,	• Network protections such as firewalls + ACLs must reduce attack surface. (12) • CCTV systems must be isolated, patched, and firewall-segmented. (9) • Administrative access limited to approved IPs only (FortiProxy). (14) • Admin interfaces must operate in isolated Layer-2 management VLANs. (11) 7.4 Application / Web Security Requirements • VIBES input must be validated and sanitised to prevent XSS. (3) • Public-facing endpoints must be restricted or disabled when not required. (6) • Sensitive API activity must include cryptographically secure nonces. (8) • Cloudflare Transform Rules must whitelist approved HTTP headers only. (13) 7.5 Secure Monitoring & Communication • Encryption mandatory for security monitoring and sensitive traffic to prevent eavesdropping. (16) 8 Data Protection Requirements (UK GDPR) Suppliers processing personal data must: • Sign a Data Processing Agreement • Follow data minimisation & purpose limitation	
---	---	--

these may form part of a contract – such as an employee contract or a contract a student signs before coming to university. Whatever the case, ensure the ‘punishment’ for policy violations is necessary and proportionate to the violation. The vast majority of times, policy violations are relatively minor and can be treated with training and education. Three key points for policy violations: Gather information on an incident response form (more on incident response in later units) If you’re going to accuse someone of something, you need to be certain of your evidence. Remember, auditability and accountability are fundamental in information security/assurance and that goes both ways. Define the disciplinary/legal action to be pursued Identity who to contact in case of intrusion	• Apply encryption + access controls to protect confidentiality • Support incident reporting within 72 hours to meet UK GDPR deadlines 9 Acceptable Use & Prohibited Activities <i>(Based on your example)</i> Suppliers shall NOT: • Access airport systems beyond their contractual need • Circumvent or disable security controls • Store airport data outside approved environments • Modify or expose airport operational systems to external networks Breaches trigger investigation and contractual consequences. 10 Auditability & Accountability Suppliers must: • Maintain logs showing compliance with this policy • Support audits and penetration testing • Provide proof of access reviews, patch status, and remediation Failure to demonstrate these may lead to suspension of service. 1 1 Incident Response & Reporting Contacts Suppliers must:	
---	--	--

	• Report security events to [Airport Name] immediately • Use airport-approved incident reporting channels • Provide evidence, logs, and technical detail as requested For urgent issues → contact: security@[placeholder].co.uk or CISO office contact details 1 2 Violations of this Policy Violations will be investigated under established procedures: 1 Evidence is gathered according to incident response standards 2 Suppliers are notified and required to support investigations 3 Consequences may include: • Mandatory retraining • Corrective action plan • Contractual penalties • Access termination • Legal/regulatory escalation under UK GDPR Disciplinary measures must remain necessary and proportionate.	
	1 3 Exceptions No exceptions unless: • Formally documented • Risk assessed	

		• Approved by the CISO and DPO	
		1 4 Review and Revision This policy will be reviewed annually or after: • Significant change in airport operations • New regulatory/cybersecurity requirements • Supplier non-compliance issues	
7	Remove Asset Overview section and update final policy with proper formatting and professionally, also do not use emojis.	Understood. Below is the final professionally formatted policy: • No emojis • No “Asset Overview” section (fully removed) • Clear structure aligned with industry standards • Maintains your 17 risk-driven policy requirements • UK and aviation context preserved • Approximately 1400–1500 words (within 3-page expectation) You may replace the placeholder airport name and contact details before submission.	
		INFORMATION SECURITY IN SUPPLIER AGREEMENTS POLICY [Airport Name] – United Kingdom Version 1.3 Status: Approved	

		1. Policy Development and Governance This policy has been created under guidance from the Information Security Management System (ISMS) and developed collaboratively by the following stakeholder groups: • Information Security / CISO Office • Legal and Procurement Departments • IT and Operational Technology (OT) Management • Data Protection Officer (DPO) • Senior Administration Representative • Staff Representative • Technical Policy Editor This governance structure ensures operational, legal, technical, and personnel considerations are fully incorporated.	
		2. Organisational Context and Security Approach [Airport Name] is designated as Critical National Infrastructure. The confidentiality, integrity, and availability of airport operational systems and passenger data are essential to: • Safe aircraft movement and airport operations • Protection of passengers and employees • Maintenance of public trust and regulatory compliance Accordingly, the organisation adopts a strict and restrictive security posture, whereby:	

		Access to airport data and systems is denied by default and granted only where explicitly required and authorised. All suppliers must support this security stance and comply with the controls mandated under this policy.	
		3. Risk and Threat Considerations Supplier relationships introduce potential for: • Unauthorised access and identity compromise • Data breaches affecting passenger privacy • Disruption of operational technology • Vulnerability exploitation due to delayed patching • Privilege escalation resulting in loss of system integrity • Network intrusion and lateral movement • Eavesdropping on security monitoring channels This policy establishes minimum mandatory controls addressing those risks as part of supply chain resource management aligned with ISO/IEC 27001 Annex A.	
		4. Purpose The purpose of this policy is to ensure that suppliers implement robust and auditable information security and data protection controls within their contractual obligations to [Airport Name]. Suppliers must enable ongoing compliance with UK GDPR, ISO/IEC	

		27001, and UK regulatory frameworks applicable to aviation security.	
		5. Scope This policy applies to all suppliers, contractors, cloud service providers, and subcontractors who: • Access, process, or store personal data on behalf of [Airport Name] • Support or maintain airport operational IT or OT systems • Connect to or manage airport networks, applications, and security platforms It applies throughout the supplier lifecycle including onboarding, delivery, and contract termination.	
		6. Policy Statements and Information Security Controls 6.1 Privileged Access and Authentication Controls • Privileged access rights must be allocated strictly according to the principles of least privilege and role-based access control. • Privileged accounts must be reviewed quarterly and immediately revoked when access is no longer required. • All Oracle platform implementations must enforce strict session management and ensure user access is restricted to necessary business functions.	

		• Multi-factor authentication must be enforced for all access to airport systems and services. • Authentication attempts from unknown devices or user agents must be blocked through behavioural analytics where feasible. (Policy requirements referenced: 1, 7, 15)	
		6.2 System Hardening and Patch Management • All systems associated with flight-tracking services must be fully patched and maintained to ensure continued operational availability. • Operating systems must be patched promptly and virtualisation security must be actively managed to reduce privilege escalation risk. • Vulnerable kernel modules must be disabled or patched to maintain system integrity. • All affected devices must be identified, vulnerability-assessed, and remediated through timely updates and physical access security. (Policy requirements referenced: 2, 4, 10, 17)	
		6.3 Network and Infrastructure Security • Only explicitly approved management devices and Microsoft Update servers may access patch management infrastructure such as WSUS. • Network traffic from unapproved systems must be blocked, including	

		mandatory blocking of inbound traffic to TCP ports 8530 and 8531. • Firewall rules and access control lists must be applied to reduce the exposed attack surface. • CCTV and surveillance systems must be segmented from external networks, patched regularly, and protected using secure firewall controls. • Management interfaces must only be accessed from authorised administrative networks and isolated within Layer-2 management VLANs. • Administrative access to secure web gateway environments must be restricted strictly to authorised and approved IP addresses. (Policy requirements referenced: 5, 9, 11, 12, 14)	
		6.4 Application and Web Security • All web services must validate and sanitise input before storage or display to prevent cross-site scripting and other injection attacks. • Public-facing application endpoints shall be disabled unless specifically required and risk assessed for operational use. • Cryptographically secure nonce values must be applied to all sensitive system transactions and API operations to prevent replay or request forgery. • Where Cloudflare or comparable services are used, only approved and trusted HTTP headers shall be	

		permitted; ambiguous or attacker-controlled headers are prohibited. (Policy requirements referenced: 3, 6, 8, 13)	
		6.5 Secure Monitoring and Communications • All security monitoring systems must use encryption mechanisms to protect monitoring data from eavesdropping or manipulation. (Policy requirement referenced: 16)	
		7. Data Protection Requirements (UK GDPR) Suppliers processing personal data on behalf of [Airport Name] shall: • Sign and adhere to a Data Processing Agreement • Process only data instructed by [Airport Name] • Maintain strict access controls and security logging • Comply with data minimisation and lawful basis requirements • Support data subject rights in the required statutory timeframe • Report any personal data breach without undue delay • Support legal/regulatory breach notifications within 72 hours where necessary Passenger data confidentiality must be upheld at all times.	

		8. Acceptable Use and Prohibited Activities Suppliers shall not: • Disable or bypass security controls without approval • Connect unapproved devices or remote tools to airport networks • Store airport data outside authorised systems • Share authentication credentials with unauthorised personnel • Perform system changes without airport-approved change management Use of airport systems is strictly limited to contractually authorised purposes.	
		9. Audit, Monitoring, and Compliance Management Suppliers must: • Provide access to security logs, patching evidence, and configuration records • Support risk assessments, penetration testing, and security audits • Maintain compliance throughout the contract lifecycle • Cooperate fully with forensic investigations if required Failure to demonstrate compliance constitutes a breach of this policy.	

		10. Incident Reporting Requirements Suppliers must: • Report actual or suspected cybersecurity incidents immediately to [Airport Name] • Ensure preservation of evidence relevant to investigations • Not apply corrective action that may interfere with forensic analysis without approval Primary Contact: security@[placeholder-domain].co.uk Escalation Contact: [CISO contact placeholder]	
		11. Subcontractor Controls Subcontracting of services involving airport systems or personal data is prohibited unless: • Written approval is provided by [Airport Name] • Flow-down clauses ensure subcontractors are fully bound by this policy Suppliers remain accountable for the actions of any subcontractors used.	
		12. Non-Compliance and Policy Violations Violations of this policy may result in: • Mandatory remedial actions • Suspension or revocation of system access	

		• Contractual penalties or contract termination • Regulatory reporting to authorities such as the ICO or CAA • Legal action where applicable Any disciplinary action will be proportionate to the severity of non-compliance.	
		13. Exceptions Exceptions may only be granted where: • Documented business justification is provided • Risks are assessed and mitigated • Written approval is issued by both the CISO and DPO No control may be bypassed without approved risk acceptance.	
		14. Review and Maintenance This policy shall be reviewed: • Annually, or • Following major regulatory, technological or supplier-related changes Version control must be maintained in the ISMS document register.	
		If you would like, I can provide:	

		1. A Word document version (.docx) fully formatted for your submission 2. Optional Appendix for your report: ○ ISO/IEC 27001 Annex A mapping ○ Risk-to-control traceability matrix Would you prefer the placeholder name to be: • UK International Airport (generic) • Manchester Airport • Birmingham Airport • Edinburgh Airport • Another UK airport of your choice?	
8		Absolutely — thank you for the clear direction. Below is the professionally formatted final policy with the “policy requirement referenced” notes fully removed. Everything now reads as a clean, academic and professional policy document.	
	Remove Asset Overview section and update final policy with proper formatting and professionally, also do not use emojis.	INFORMATION SECURITY IN SUPPLIER AGREEMENTS POLICY [Airport Name] – United Kingdom Version 1.4 Status: Approved	
		1. Policy Development and Governance This policy has been developed and reviewed by the Information Security Management function with involvement from:	

		• Information Security / CISO Office • Procurement and Legal Representatives • IT and Operational Technology Management • Data Protection Officer (DPO) • Senior Administration • Staff Representative • Technical Policy Writer / Editor This ensures that operational, regulatory, and contractual requirements are comprehensively addressed.	
		2. Organisational Context and Security Approach [Airport Name] is classified as a Critical National Infrastructure (CNI) entity under UK civil aviation regulations. The secure operation of airport systems and protection of passenger data are essential to maintaining: • Flight and passenger safety • Operational continuity and service availability • Public confidence and national regulatory compliance Accordingly, a strict, restrictive security posture is adopted. Access to systems and data is only permitted where explicitly justified and approved.	
		3. Risk and Threat Considerations	

		Supplier interactions introduce risk including: • Unauthorised access to systems and data • Privilege escalation through vulnerable system components • Disruption of operational services through cyber-attack • Data breaches affecting passenger privacy • Compromise of network security boundaries • Eavesdropping on security and administrative channels This policy defines mandatory preventative controls to mitigate such threats in accordance with ISO/IEC 27001.	
		4. Purpose The purpose of this policy is to ensure security, resilience, and compliance by mandating that suppliers implement appropriate information security and data protection controls when handling airport systems, networks, and personal data.	
		5. Scope This policy applies to all third-party suppliers, contractors, cloud providers, and subcontractors who: • Access, process, store, or manage passenger or employee personal data	

		• Provide or maintain any airport operational system, network, or security platform • Require network connectivity or privileged access to [Airport Name] systems It is enforceable during onboarding, throughout contract lifecycle, and at contract termination.	
		6. Policy Statements and Information Security Controls 6.1 Privileged Access and Authentication Controls • Privileged access rights must be granted on the basis of least privilege and role-based access control. • Privileged credentials shall be reviewed quarterly and revoked immediately when no longer required. • Oracle platforms must enforce strict session management and ensure access only to permitted functionality. • Strong multi-factor authentication must be implemented for all system access. • Behaviour-based controls must prevent login attempts from untrusted devices or unknown user agents.	
		6.2 System Hardening and Patch Management • All systems related to flight-tracking services must be fully patched and kept operational to support continuity.	

		• Operating systems must be patched in a timely manner with secure virtualisation configurations. • Vulnerable or outdated kernel modules must be disabled or patched to prevent privilege escalation. • Affected devices must be identified, assessed, and remediated using a combination of timely updates and strict physical controls.	
		6.3 Network and Infrastructure Security • Only authorised management hosts and Microsoft Update servers may access patch management servers such as WSUS; all unapproved inbound connections to relevant TCP ports must be denied. • Firewall rules and access control lists must be applied to reduce the attack surface of network services. • CCTV and surveillance systems must be isolated from external networks using secure segmentation and maintained with routine patching. • Administrative interfaces must only be accessible from authorised networks and isolated using Layer-2 management VLANs. • Secure web gateway management interfaces must only be reachable from approved IP addresses.	
		6.4 Application and Web Security • All web application input must be validated and sanitised to protect	

		against code injection and cross-site scripting. • Public-facing application endpoints must remain disabled unless operationally necessary and risk assessed. • Cryptographically secure nonce values must protect API and sensitive transaction requests. • Trusted HTTP headers must be strictly whitelisted, ensuring that attacker-controlled headers cannot affect filtering or caching logic.	
		6.5 Security Monitoring and Communications • Encryption must be applied to all security monitoring data and administrative communications to protect against interception and tampering.	
		7. Data Protection Requirements (UK GDPR) Suppliers who process personal data on behalf of [Airport Name] must: • Execute a Data Processing Agreement before processing begins • Process personal data solely according to documented airport instructions • Maintain strict access governance and activity logging • Comply with principles of data minimisation and purpose limitation • Facilitate data subject rights within regulated timeframes	

		• Notify the airport immediately of any personal data breach • Enable regulatory breach reporting within 72 hours, if required Passenger and staff privacy must be protected at all times.	
		8. Acceptable Use and Prohibited Activities Suppliers must only use airport systems for contractual business purposes and shall not: • Attempt to bypass established security controls • Connect unapproved devices or tools to airport networks • Remove, export, or store airport data outside approved environments • Share or reuse privileged authentication credentials • Implement system changes without formal change-control approval Unacceptable use will trigger compliance action. 9. Audit, Monitoring, and Assurance Suppliers must: • Provide full visibility of compliance through logs, reports, and access reviews • Participate in airport-led or independent audits and assessments • Support penetration testing and security monitoring activities	

		• Provide evidence of timely remediation for identified vulnerabilities Failure to demonstrate compliance constitutes policy violation and may halt service delivery. 10. Incident Reporting Requirements Suppliers must: • Report suspected or confirmed incidents immediately to [Airport Name] • Preserve relevant evidence including logs and configuration data • Avoid unauthorised remediation actions that could disrupt forensic activities Primary contact: security@[placeholder-domain].co.uk Escalation contact: [CISO contact placeholder] 11. Subcontractor Controls Subcontracting is prohibited unless: • Explicit written approval has been granted • Subcontractors contractually adhere to the same requirements detailed in this policy Suppliers remain fully accountable for subcontractor actions affecting airport security.	
		12. Non-Compliance and Enforcement Violations of this policy may result in: • Mandatory corrective action	

		• Suspension or withdrawal of systems access • Contract termination and financial penalties • Regulatory reporting to relevant authorities (ICO, CAA) • Legal or civil action where justified Corrective measures must be proportionate to the severity of non-compliance. 13. Exceptions Exceptions may only be granted where: • A documented business justification exists • Security and privacy risks are assessed and mitigated • Written approval is provided by both the CISO and DPO No unauthorised deviations are permitted. 14. Review and Maintenance This policy shall be reviewed: • Annually, or • After significant changes in technology, regulation, risk, or supplier arrangements All modifications must be controlled and recorded within the ISMS. Final Check Options I can deliver this policy in a formatted Word document (.docx) with: • Custom airport name added	
--	--	---	--

		• Page numbering, references and footer • Table of contents (optional) • Professional formatting (header with logo placeholder, ISMS doc ID, approval signature fields) Before I generate that final document: Which airport name should I apply? Examples: • Manchester Airport • Birmingham Airport • UK International Airport (generic) • Or any airport name you choose	
9	Can you write policy for each policy statement and put the numbering for my policy instead of bullets.	INFORMATION SECURITY IN SUPPLIER AGREEMENTS POLICY [Airport Name] – United Kingdom Version 2.0 Status: Approved 1. Policy Development and Governance This policy has been developed through collaboration between Information Security and the CISO Office, IT and Operational Technology (OT) Management, Legal and Procurement, the Data Protection Officer (DPO), Senior Administration, staff representatives, and a technical policy writer/editor. This multidisciplinary review ensures alignment with operational needs, regulatory obligations, contractual expectations, and organisational governance. 2. Organisational Context and Security Approach	

		[Airport Name] operates as a part of the United Kingdom’s Critical National Infrastructure. The resilience and security of the airport’s information systems, operational environments, and personal data processing are essential to the protection of life, business continuity, aviation safety, corporate reputation, and compliance with statutory and regulatory requirements. The airport enforces a strict security posture in which access is denied by default and only granted when explicitly authorised and justified.	
		3. Risk and Threat Considerations Suppliers introduce a number of potential risks to airport operations and data security. These include the risk of unauthorised access or misuse of privileged functionality, operational disruption caused by exploitation of technical vulnerabilities, loss of service availability, breaches of personal data, compromise of surveillance and physical security systems, and interception or manipulation of communications. This policy mandates controls to ensure that such risks are effectively identified, mitigated, and managed throughout the supplier relationship lifecycle.	
		4. Purpose The purpose of this policy is to ensure that information security and data protection requirements are embedded within all supplier engagements and contract agreements. It seeks to protect the confidentiality, integrity, and availability of airport information assets and systems while ensuring full compliance with standards such as ISO/IEC 27001 and legal frameworks including UK GDPR.	
		5. Scope	

		This policy applies to all suppliers, contractors, managed service providers, cloud service providers, and subcontracted entities engaged by [Airport Name] who access or process airport information, support or maintain IT or OT assets, or connect any component to the airport network. Compliance requirements apply from the point of procurement and onboarding through operational delivery and eventual offboarding, including data return or secure destruction.	
		6. Information Security Policy Requirements <i>(Revised – 17 standalone policies)</i> 6.1 Privileged Access Policy Privileged access must be restricted to the minimum necessary, reviewed quarterly, and immediately revoked when no longer required to prevent misuse of elevated permissions. 6.2 System Update and Patch Policy All systems that suppliers manage for the airport must be maintained in a fully updated and patched state to reduce the risk of service disruption and security compromise. 6.3 Input Validation Policy All application inputs must be validated and sanitised prior to processing, storage, or display to protect systems from injection and cross-site scripting attacks. 6.4 Secure Configuration Policy Systems must be securely configured, disabling weak or vulnerable components and applying security controls to prevent privilege escalation and unauthorised system modification. 6.5 Restricted Update Infrastructure Policy	

		Update and management infrastructure must only be accessible to authorised systems and required update services, and all other inbound connectivity must be actively blocked. 6.6 Public Interface Hardening Policy Public-facing application interfaces and unnecessary externally accessible functions must be disabled or restricted, ensuring only approved endpoints remain available. 6.7 Role-Based Data Access Policy Access to data must be strictly role-based, ensuring that users, systems, and integrations access only the information required for operational responsibilities. 6.8 Transaction Integrity Policy Sensitive transactions and API operations must use secure cryptographic controls such as nonces to prevent replay, manipulation, or unauthorised execution. 6.9 Physical Security System Segmentation Policy Surveillance and physical security systems must be segmented from public networks, regularly updated, and protected using secure firewall controls to prevent unauthorised access. 6.10 Asset Remediation Policy All vulnerable or affected devices must be identified, assessed, and remediated with appropriate technical, physical, or administrative controls within acceptable timeframes. 6.11 Administrative Access Isolation Policy Administrative interfaces must only be accessible from authorised management	
--	--	--	--

	networks and isolated within dedicated and secure network segments. 6.12 Network Access Control Policy Firewall rules and access control lists must be applied to limit connectivity to only required services, reducing attack surface and exposure to unauthorised access. 6.13 Web Traffic Header Protection Policy Web communications must enforce protections that prevent unauthorised modification of request or response headers and ensure only trusted and validated metadata is processed. 6.14 Secure Proxy Administration Policy Administrative access to security gateways, proxies, and similar systems must be restricted to approved IP addresses and authorised personnel only. 6.15 Authentication Security Policy All authentication services must enforce strong multi-factor authentication and monitor for suspicious activity, blocking sign-in attempts from untrusted or anomalous sources. 6.16 Secure Monitoring Communication Policy Monitoring and security telemetry systems must encrypt communication channels and implement protections that prevent interception and unauthorised disclosure of security data. 6.17 Operating System Security Policy Operating systems must be patched promptly and configured to disable or manage features that could enable privilege escalation or execution of malicious processes.	
--	--	--

		7. Data Protection Requirements (UK GDPR) Suppliers processing personal data on behalf of the airport must do so only under the explicit instruction of the airport in accordance with lawful processing requirements. A Data Processing Agreement will govern responsibilities, ensuring appropriate technical and organisational measures, restricted access to personal data, accountability for audit logging, and support for data subject rights. Any incident involving personal data must be reported without undue delay to enable regulatory notification as required. The airport remains the Data Controller at all times.	
		8. Acceptable Use and Prohibited Practices Suppliers are required to operate within the airport's approved security framework and must not bypass established security controls, introduce unauthorised technology or connectivity, export data beyond approved environments, or make operational changes without prior authorisation. Sharing or reusing privileged credentials or authentication materials is strictly prohibited, and any such behaviour may trigger contractual or legal response.	
		9. Audit, Monitoring and Compliance Enforcement Suppliers must provide evidence of compliance upon request and allow the airport or authorised third parties to conduct audits, assessments, and penetration testing where necessary. Suppliers are expected to provide logs, patch records, and remediation documentation and cooperate fully with incident investigations. Contractual enforcement actions will be applied proportionately where non-compliance is identified.	

		10. Incident Reporting Requirements Suppliers are required to immediately report any suspected or confirmed security incidents to the designated airport security contact, maintain the integrity of digital evidence, and refrain from changes that could hinder forensic investigation or remediation. Escalation contacts must be made available to the airport.	
		11. Subcontractor Controls Any subcontracting arrangement must be formally approved in writing by the airport before engagement. Subcontractors must adhere to the same security requirements as the primary supplier, and primary suppliers remain fully accountable for the performance and compliance of their subcontractors.	
		12. Enforcement and Policy Violations If a supplier breaches this policy, the airport may enforce appropriate sanctions including suspension of access, service discontinuation, contract termination, financial recovery of loss or damages, and escalation to regulatory bodies. Enforcement decisions will be guided by the severity and risk impact of the violation.	
		13. Exceptions Any deviation from this policy must be formally documented, fully risk assessed, and approved by both the CISO and the Data Protection Officer. Unauthorised exceptions are not permitted under any circumstances.	

		14. Review and Maintenance This policy will be reviewed at least annually or following significant changes in regulatory obligations, supplier arrangements, or cyber risk conditions. Any updates made must follow appropriate ISMS change governance.	
--	--	--	--

Self Evaluation of the AI Tool

- To create the whole policy for LHR I used ChatGPT. It was much quicker than creating the whole policy without the use of ChatGPT.
- It was able to create the structure and suggest the headers needed for policy creation as well. It was also able to correctly identify the frameworks which should be included and create the policy in a professional way. ChatGPT was able to create general policy based on the policy statements I gave and it was very efficient.
- Since ChatGPT could restructure, change format, add or remove bullet points or change them to sentences, it really helped in creating the policy as per my preference instead of giving a very general policy.
- But in some cases, it misunderstood my instructions due to which I had to do multiple iterations to come to a final version (Mollick, 2023).
- I also had to keep the AI hallucination factor in mind, which means someone using ChatGPT for creating policy should be very knowledgeable and thorough to identify any false information or outdated information given by ChatGPT (IBM, 2023).
- In my personal experience, giving prompts to ChatGPT as if talking to a human did not generate better responses in comparison to giving straight instructions (Mollick, 2023).
- In regards to privacy and ethical consideration, I did not disclose the Airport name or any personal, sensitive or confidential information which could breach the CIA. To be GDPR compliant and not breach confidentiality, I asked it to consider any airport in the UK and use it as placeholder to create the policy.
- Once the last version of the policy was generated by ChatGPT with placeholder information, I edited the placeholder information with the actual data of Heathrow Airport and the assets myself to create the final version.
- Overall ChatGPT AI can be a very powerful tool to leverage, however the extent of use and awareness of breaches to CIA in anyway should remain with the individual.